

국가(기술)자격검정 필기시험문제

2022년도 제4회 정기검정

자격종목 및 등급(선택분야)

정보보안기사

시험시간

2시간 30분

문제지형별

2형

수험번호

성명

[가답안 확인]



* 답안카드 작성시 시험문제지 형별누락, 미검각으로 인한 불이익은 전적으로 수험자의 귀책사유임을 알려드립니다.

시스템보안

1. 다음 중 Directory Traversal 공격에 대한 설명으로 옳은 것은?

- ① 공격자가 OS의 조작 커맨드를 이용하는 어플리케이션에 대해서 OS의 디렉토리 작성 커맨드를 삽입하여 실행한다. X
- ② 공격자가 입력 파라미터 등에 SQL문을 삽입하여 어플리케이션에 임의의 SQL문을 전달하여 실행한다. X
- ③ 공격자가 실금 사인온을 제공하는 디렉토리 서비스에 대해 무단으로 얻은 자격 증명을 사용하여 로그인하고 여러 응용 프로그램을 무단으로 사용한다. X
- ④ 공격자는 파일 이름을 입력하는 응용 프로그램에 대해 상위 디렉토리를 의미하는 문자열을 사용하여 비공개 파일에 액세스한다. O

2. 운영체제를 설치할 때 파티션을 분할하는 이유가 아닌 것은?

- ① 각각 볼륨에서 발생된 문제가 다른 볼륨으로 전이되는 것을 방지할 수 있다. O
- ② 시스템영역과 사용자영역이 분리되어 있으므로 백업이 용이하다. O
- ③ SUID 공격에 대해 단일 파티션보다 안전하다. O
- ④ 파일시스템 성능은 단일 파티션보다 낮아진다. X

3. 다음 문장의 기능을 수행하기 위한 Nmap의 옵션은?

해당 스캐닝 기법은 방화벽이 존재하더라도 해당 서버에 서비스가 오픈되어 있는지, 필터링이 되어 있는지 등을 파악하기 위해 사용되며, 다른 스캔기법보다 더 비밀스럽고 타겟 호스트에 로그가 남지 않는 방법이다.

- ① -sU X
- ② -sP X
- ③ -sS O
- ④ -sT X

4. 무작위 대입공격(Brute-Force Attack) 및 사전공격(Dictionary Attack) 등 사용자의 패스워드 크래킹 취약점을 점검하기 위한 도구가 아닌 것은?

- ① John the Ripper O
- ② L0phtcrack O
- ③ Rwdump X
- ④ WinNuke O

5. 접근통제 모델 중 주체나 그들이 소속되어 있는 그룹들의 ID에 근거하여 객체에 대한 접근을 제한하는 접근통제 방식은?

- ① 임의적 접근통제(Discretionary Access Control)
- ② 강제적 접근통제(Mandatory Access Control)
- ③ 직무기반 접근통제(Task-based Access Control)
- ④ 역할기반 접근통제(Role-based Access Control) O

6. 다음 중 파일 디스크립터(File Descriptor)에 대한 설명으로 틀린 것은?

- ① 사용자가 직접 관리하므로 사용자가 참조할 수 있다. X
- ② 파일을 관리하기 위해 시스템이 필요로 하는 정보를 보관한다. O
- ③ 일반적으로 보조기억장치에 저장되어 있다가 파일을 오픈(Open)할 때 주기억장치로 옮겨진다. O
- ④ 파일 제어 블록(File Control Block) 이라고도 한다. O

7. 유닉스 시스템 계열에서 파일 무결성 검사 도구는?

- ① umask X
- ② mount X
- ③ tripwire O
- ④ TCP-wrapper X

8. 다음 문장에서 설명하는 것은?

실시간 트래픽 분석과 IP 네트워크상에서 패킷 로깅이 가능한 가벼운(Lightweight) 네트워크 침입탐지시스템이다. 프로토콜 분석, 내용 검색/매칭을 수행할 수 있으며 오버플로우, Stealth 포트스캔, CGI 공격, SMB 탐색, OS 확인 시도 등의 다양한 공격과 스캔을 탐지할 수 있다.

- ① Tripwire X
- ② Wireshark X
- ③ Snort O
- ④ iptables X

9. 버퍼 오버플로우에 대한 대책이 아닌 것은?

- ① Non-Executable 스택 사용 O
- ② rtl(return to libc) 사용 X
- ③ 스택 가드(Stack Guard) 또는 스택 쉴드(Stack Shield) 사용 O
- ④ ASLR(Address Space Layout Randomization) 사용 O

10. 다음 문장에서 설명하는 스토리지는?

공격자가 시스템의 로그 파일을 삭제하거나 변조한다면 공격자가 어떠한 행위를 하였는지 파악하는데 어려움이 존재한다. 이러한 이슈를 해결하고자 로그의 위변조 방지를 위해 사용한다.

- ① HOT 스토리지 X
- ② WORM 스토리지 O
- ③ DISK 스토리지 X
- ④ NAS 스토리지 X

11. 제로데이 공격의 특징은?

- ① 보안 패치가 제공되기 전에 알려지지 않은 취약점을 이용하여 공격한다. O
- ② 특정 웹 사이트에 대해 날짜와 시간을 결정하고 여러대의 PC에서 동시에 공격한다. X
- ③ 특정 대상에게 피싱 메일을 보내 불법 사이트로 안내한다. X
- ④ 부정 중계가 가능한 메일 서버를 찾은 후 그것을 기반으로 체인 메일을 대량으로 송신한다. X

12. ICMP 패킷에 응답하지 못하도록 실행하는 명령은?

- ① sysctl -w kernel.ipv4.icmp_echo_ignore_all=0
- ② sysctl -w kernel.ipv4.icmp_echo_ignore_all=1 O
- ③ sysctl -w kernel.ipv4.icmp_echo_ignore_broadcasts=0
- ④ sysctl -w kernel.ipv4.icmp_echo_ignore_broadcasts=1

13. 윈도우 시스템에서 administrator 계정의 암호를 마지막으로 변경한 날짜를 확인하는 명령어는?

- ① passwd
- ② net user administrator, O
- ③ net share
- ④ net date

14. 패스워드 복잡성 설정을 위한 OS별 해당 파일이 올바르게 찍혀진 것은?

- ① SOLARIS, /etc/security/pwquality.conf
- ② LINUX(RHEL5), /etc/pam.d/system-auth O
- ③ AIX, /etc/default/passwd
- ④ LINUX(RHEL7), /etc/default/security

15. 다음 지문은 어느 웹 서버의 로그이다. ()를 통해 알 수 있는 정보는?

```
17.248.161.109 - - [04/Jun/2014:16:03:55 +0900] "POST http
/Upload_Process.php HTTP/1.1" 200 14105
17.248.161.109 - - [04/Jun/2014:16:04:18 +0900] "GET
/bbs/up/KA_ushell.php/bbs/up/KA_ushell.php HTTP/1.1" 200 1443
17.248.161.109 - - [04/Jun/2014:16:04:21 +0900] "GET
/bbs/up/KA_ushell.php?acKA_ushell.php?ac=shell HTTP/1.1" 200 1443
17.248.161.109 - - [04/Jun/2014:16:04:22 +0900] "GET
/bbs/up/KA_ushell.php?acKA_ushell.php?ac=upload HTTP/1.1" 200 1546
17.248.161.109 - - [04/Jun/2014:16:04:25 +0900] "GET
/bbs/up/KA_ushell.php?acKA_ushell.php?ac=eval HTTP/1.1" 200 1400
17.248.161.109 - - [04/Jun/2014:16:04:27 +0900] "GET
/bbs/up/KA_ushell.php?acKA_ushell.php?ac=shell HTTP/1.1" 200 1443
17.248.161.109 - - [04/Jun/2014:16:04:31 +0900] "POST
/bbs/up/KA_ushell.php?acKA_ushell.php HTTP/1.1" 200 1491
17.248.161.109 - - [04/Jun/2014:16:04:34 +0900] "POST
/bbs/up/KA_ushell.php?acKA_ushell.php HTTP/1.1" 200 1502
17.248.161.109 - - [04/Jun/2014:16:04:39 +0900] "POST
/bbs/up/KA_ushell.php?acKA_ushell.php HTTP/1.1" 200 8210
17.248.161.109 - - [04/Jun/2014:16:04:45 +0900] "POST
/bbs/up/KA_ushell.php?acKA_ushell.php HTTP/1.1" 200 4024
17.248.161.109 - - [04/Jun/2014:16:04:52 +0900] "POST
/bbs/up/KA_ushell.php?acKA_ushell.php HTTP/1.1" 200 1502
```

- ① IIS(Internet Information Services) 웹 서버 로그이다.
- ② 클라이언트가 사용하는 웹 브라우저를 알 수 있다.
- ③ 헤더를 포함한 데이터 크기를 알 수 있다.
- ④ 서버에서 클라이언트로 전송한 데이터 크기를 알 수 있다. O

16. 쿠키(Cookie)의 속성 중 Set-Cookie 응답 헤더에 설정하는 속성으로 클라이언트(웹 브라우저 등)에서 스크립트(자바 스크립트 등)를 통해 해당 쿠키에 접속하는 것을 차단해 주는 속성은?

- ① path 속성 ② httpOnly 속성
③ domain 속성 ④ secure 속성

17. 리눅스(Linux) inode의 블록관리(Block Management) 방법에 해당하지 않는 것은?

- ① Single Indirect Block
② Double Indirect Block
③ Triple Indirect Block
④ Quadruple Indirect Block

18. 악성코드 구동을 위하여 사용되는 윈도우 레지스트리는?

- ① HKEY_CLASSES_ROOT ② HKEY_USERS
③ HKEY_CURRENT_USER ④ HKEY_CURRENT_CONFIG

19. 유닉스 시스템에서 실행중인 프로세스별 CPU 점유율, 메모리 점유율, 시스템 부하율 등 전반적인 모니터링이 가능한 명령어는?

- ① df ② iostat
③ netstat ④ top

20. 안드로이드 앱의 SSL 연결시 CA 등록을 통한/중간자 공격을 방어하기 위해 도입된 기술은?

- ① App Signing ② SSL Pinning
③ IDS ④ IPS

네트워크보안

21. 해커의 위치를 실시간으로 추적하는 기술인 역추적(Traceback) 중 IP Traceback, StackPi 등은 어떤 모델인가?

- ① 출발지 적용가능 모델 ② 중계지 적용가능 모델
③ 도착지 적용가능 모델 ④ 근원지 적용가능 모델

22. 다음 중 MDM(Mobile Device Management)의 기능과 관리내용으로 틀린 것은?

- ① 기능: 보안 관리 및 도난 방지, 관리 내용: 기기의 루팅 탐지 및 차단
② 기능: 앱 관리, 관리 내용: 원격 앱 설치 및 관리
③ 기능: 자산 관리, 관리 내용: 기기 분실 관리
④ 기능: 설정 관리, 관리 내용: 네트워크 설정

23. 네트워크 보안 솔루션에서 탐지되는 특정 패턴과 시계열(time series) 데이터의 조합에 의한 보안 상관분석은?

- ① 특정한 패턴에 대한 분석 ② 임계치 값에 의한 분석
③ 정책기반 상관분석 ④ 시나리오기반 상관분석

24. 다음 문장에서 설명하는 공격은?

이것은 인텔 CPU에서 사용하는 비순차적 명령 실행(Out of Order Execution)의 특권명령(Privileged instruction) 검사 우회 버그를 악용하여 해킹프로그램이 CPU의 캐시 메모리에 접근하고, 데이터를 유출하는 공격이다.

- ① 캐시 포이즈닝 ② 스캐터
③ 멜트다운 ④ 미라이

25. 다음과 같은 경우에 사용되는 네트워크 환경 설정 파일은?

- DNS 서버가 작동하지 않을 때
- 별도의 네트워크를 구성하여 임의로 사용하고자 할 때
- 다른 IP 주소를 가진 여러 대의 서버가 같은 도메인으로 클러스터링(clustering)되어 운영되는 상태에서 특정 서버에 접속하고자 할 때
- 잘못된 환경 설정이 서버접속 자체를 막으며 해킹 등에 오용될 수 있을 때

- ① inetd.conf 파일 ② hosts 파일
③ services 파일 ④ named.conf 파일

26. 데이터 복구 기법 피하기(Data Sanitization) 방법으로 틀린 것은?

- ① 데이터 지운 ② 디가우징(Degaussing)
③ 물리적으로 디스크 파괴 ④ 데이터 덮어쓰기

27. 무선통신 환경에서 사용되는 보안 프로토콜 중 다음 문장에서 설명하는 프로토콜은?

IEEE802.11i 규격을 완전히 수용하는 표준 프로토콜이다. 이전 WEP의 취약점을 보완한 대안 프로토콜로 AES-CCMP를 통한 암호화 기능 향상, EAP 사용자 인증 강화 등이 포함된다.

- ① WPA ② WPA2
③ SSID ④ TKIP

28. IPsec의 터널 모드(Tunneling Mode)에서 AH(Authentication Header)를 추가한 IP Packet 구성순서로 옳은 것은?

- ① New IP Header - AH - Original IP Header - Original Payload
② AH - New IP Header - Original IP Header - Original Payload
③ AH - New IP Header - AH - Original IP Header - Original Payload
④ New IP Header - Original IP Header - Original Payload - AH

29. 스누핑 방법 중 주로 시스템간 트러스트(신뢰) 관계를 이용하기 위해 사용되는 공격방법은?

- ① IP 스누핑 ② DNS 스누핑
③ ARP 스누핑 ④ Host 스누핑

30. Memcached DDoS 공격 기법에 대한 설명으로 틀린 것은?

- ① 공용 네트워크 상에 공개되어 있는 대량의 Memcached 서버(분산식 캐시 시스템)에 존재하는 인증과 설계의 취약점을 이용한다.
② 스니핑 기법을 이용해 더 많은 트래픽을 발생시킨다.
③ 공격자는 일반적으로 UDP 11211 포트를 이용하여 공격한다.
④ 이러한 공격 방식을 Amplification Attack(증폭 공격) 이라고도 한다.

31. 다음 문장에서 설명하는 것은?

인터넷이나 기타 다른 네트워크의 메시지가 호스트에 도착했을 때, 전달되어야 할 특정 프로세스를 인식하기 위한 방법으로 TCP와 UDP에서 단위 메시지에 추가되는 헤더 내에 들어있는 16비트 정수의 형태를 갖는다. 이것을 사용하여 호스트에 전달된 데이터를 상위 응용프로그램에 넘겨줄 수 있다. 웹 서비스나 파일 전송 서비스, 전자우편과 같은 서비스에 대하여 영구적으로 이것을 할당한다.

- ① port number ② protocol
③ checksum ④ routing

32. APT(Advanced Persistent Threat) 공격과정에 대한 순서를 올바르게 나열한 것은?

- ① 특정 표적을 대상으로 목표를 정한다.
② 지속적으로 정보를 수집한다.
③ 특정 표적이 된 대상으로 침투하여 해를 끼친다.
④ 복잡적이고 지능적인 수단(다양한 해킹기술)을 이용한다.

- ① ① → ② → ③ → ④ ② ② → ① → ③ → ④
③ ③ → ② → ① → ④ ④ ④ → ① → ② → ③

33. 다음 문장에서 괄호 안에 들어갈 단어는?

침입탐지시스템(IDS, Intrusion Detection System)은 대상 시스템의 보안 정책을 파괴할 수 있는 침입들을 실시간으로 탐지하는 기능을 가진 보안 시스템이다. 탐지 영역을 중심으로 분류하면 시스템 내부에 설치되어 내부 사용자나 외부 사용자의 비인가적 행위나 해킹 시도를 탐지하는 ()와 네트워크 상의 패킷정보를 분석해서 공격을 탐지하는 ()로 분류할 수 있다. 또한, 탐지 방법을 중심으로 분류하면 알려진 축적된 공격 정보를 이용해 ()를 탐지하는 (), 정상 행위와 비정상 행위를 분류해 이를 기준으로 사용자의 행위가 정상 행위인지에 대한 여부를 조사함으로써 ()를 탐지하는 ()으로 분류할 수 있다.

- ① ① Network-based IDS, ② Host-based IDS, ③ Behavior-base
④ Misused Detection, ⑤ Knowledge-base, ⑥ Anomaly Detection
② ① Network-based IDS, ② Host-based IDS, ③ Behavior-base,
④ Anomaly Detection, ⑤ Knowledge-base, ⑥ Misused Detection
③ ① Host-based IDS, ② Network-based IDS, ③ Knowledge-base,
④ Misused Detection, ⑤ Behavior-base, ⑥ Anomaly Detection
④ ① Host-based IDS, ② Network-based IDS, ③ Behavior-base,
④ Misused Detection, ⑤ Knowledge-base, ⑥ Anomaly Detection

1. 다음 문장에 대한 설명으로 옳은 것은?

- ㉠ OS에서 버그를 이용하여 루트권한 획득 또는 특정 기능을 수행하기 위한 공격 코드 및 프로그램을 의미한다. **31.악성**
 ㉡ 악의적인 프로그램을 건전한 프로그램처럼 포장하여 일반 사용자들이 의심없이 자신의 컴퓨터 안에서 이를 실행시키고 실행된 프로그램은 특정 포트를 열어 공격자의 침입을 돕고 추가적으로 정보를 자동 유출하며 자신의 존재를 숨기는 기능 등을 수행하는 공격 프로그램이다. **32.악성**

- ㉢ ㉠은 exploit 코드를 설명한다. **33.악성**
 ㉣ ㉡은 Trojan 공격프로그램을 설명한다. **34.악성**
 ㉤ ㉢은 Bomb 공격프로그램을 설명한다. **35.악성**
 ㉥ ㉣은 worm 코드를 설명한다. **36.악성**

35. 네트워크 기반 공격인 Smurf 공격의 대응방법을 모두 고른 것은?

- ㉠ 네트워크로 유입되는 패킷 중에 Source 주소가 ~~악성~~ IP인 패킷을 차단한다.
 ㉡ 라우터에서 다른 네트워크로부터 자신의 네트워크로 들어오는 IP broadcast 패킷을 막도록 설정한다.
 ㉢ IP broadcast address로 전송된 ICMP 패킷에 대해 응답하지 않도록 시스템을 설정할 수 있다.
 ㉣ 사용하지 않는 UDP 서비스를 ~~악성~~ 중지한다.

- ㉠ ㉠, ㉡
 ㉡ ㉡, ㉢
 ㉢ ㉢, ㉣
 ㉣ ㉣, ㉤

36. 방화벽의 동적 패킷 필터링 특징으로 옳은 것은?

- ㉠ IP 주소 변환이 이루어지므로 방화벽 내부의 네트워크 구성을 외부에서 숨길 수 있다.
 ㉡ 암호화된 패킷의 데이터 부분을 디코딩하여 허용된 통신인지 여부를 결정할 수 있다.
 ㉢ 리턴 패킷에 관해서는 과거에 통과한 요구 패킷에 대응하는 패킷만 통과시킬 수 있다.
 ㉣ 패킷의 데이터 부분을 확인하여 응용 프로그램 계층에서 무단 액세스를 방지할 수 있다.

37. Dynamic NAT(Network Address Translation)에 대한 설명으로 틀린 것은?

- ㉠ 하나의 NAT 시스템에서 사용하는 공인 IP는 항상 고정된 값을 사용한다.
 ㉡ 사설 IP 주소를 공인 IP 주소로 매핑하여 변환하는 프로토콜이다.
 ㉢ 내부 네트워크에서는 사설 IP 주소만 사용한다.
 ㉣ NAT을 이용하면 사설 IP 주소 대역이 노출되지 않아 보안성이 높다.

38. OSPF 프로토콜이 최단경로 탐색에 사용하는 기본 알고리즘은?

- ㉠ Bellman-Ford 알고리즘
 ㉡ Dijkstra 알고리즘
 ㉢ 거리 벡터 라우팅 알고리즘
 ㉣ Floyd-Warshall 알고리즘

39. 리눅스 시스템에서 messages 파일을 보니 다음과 같은 내용을 확인할 수 있었다. 파일의 내용을 토대로 추정할 수 있는 공격은?

Nov 10 16:36:19 chakra kernel: device eth1 entered promiscuous mode

- ㉠ Spoofing 공격
 ㉡ Sniffing 공격
 ㉢ ICMP Source Quench 공격
 ㉣ 원격접속 공격

40. 라우터에서는 출발지 주소와 목적지 주소를 기반으로 하여 패킷의 출력을 통제하는 문장을 사용하는데 이를 이용하여 패킷의 전달 여부를 제어하고, 특정 프로토콜을 사용하는 패킷의 전달을 차단하는 것은?

- ㉠ ACL
 ㉡ Frame-Relay
 ㉢ Port-Security
 ㉣ AAA

어플리케이션보안

41. 와이어샤크(WireShark) 프로그램을 이용하여 POP3 트래픽을 점검할 때, 어떤 포트를 검색해야 하는가?

- ㉠ 143
 ㉡ 110
 ㉢ 25
 ㉣ 125

42. C 언어로 작성된 응용프로그램에서 버퍼 오버플로 취약점의 발생을 방지하기 위해 사용이 권고되는 라이브러리 함수가 아닌 것은?

- ㉠ strncpy
 ㉡ scanf
 ㉢ sprintf
 ㉣ strcpy

43. 서버를 점검하던 중 다음과 같은 문장이 포함된 ASP 스크립트가 존재하는 것을 알게 되었다. 이 때 의심되는 공격은?

`%eval request("cmd")-%>`

- ㉠ Buffer Overflow
 ㉡ CSRF
 ㉢ 웹셸(WebShell)
 ㉣ DoS/DDoS

44. SET(Secure Electronic Transaction) 프로토콜의 단점이 아닌 것은?

- ㉠ 상인에게 지불정보가 노출된다.
 ㉡ 암호 프로토콜이 너무 복잡하다.
 ㉢ RSA 동작은 프로토콜의 속도를 저하시킨다.
 ㉣ 지불게이트웨이에 거래를 전자적으로 처리하기 위한 별도의 하드웨어와 소프트웨어를 요구한다.

45. 행정안전부가 통합인증 게이트웨이 기술규격에서 정의하는 SSO의 정의와 약어 풀이로 옳은 것은?

- ㉠ Signature Sign On : 일회 인증만으로 추가 인증없이 여러 시스템과 서비스를 이용할 수 있게 하는 인증서비스
 ㉡ Single Sign On : 일회 인증만으로 추가 인증없이 여러 시스템과 서비스를 이용할 수 있게 하는 인증서비스
 ㉢ Signature Sign On : 다수의 서명으로 여러 시스템과 서비스를 이용할 수 있게 하는 인증서비스
 ㉣ Single Sign On : 다수의 서명으로 여러 시스템과 서비스를 이용할 수 있게 하는 인증서비스

46. 데이터베이스 보안유형에 해당하지 않는 것은?

- ㉠ 접근 제어(Access Control)
 ㉡ 허가 규칙(Authorization Rules)
 ㉢ 가상 테이블(Views)
 ㉣ 정보 집계(Aggregation)

47. 다음은 DRM(Digital Rights Management)의 구성요소 중 무엇에 대한 설명인가?

지적재산권으로 보호되어야 할 정보의 단위로 일반적으로 패키지들 통해 패킹 되기 이전의 원본을 의미한다.

- ㉠ 콘텐츠(Contents)
 ㉡ 사용자(User)
 ㉢ 식별(Identification)
 ㉣ 권한(Permission)

48. 다음은 무엇에 대한 설명인가?

웹은 ~~서버~~기반으로 요청을 처리하는 구조이다. 해당 요청이 특정 사용자의 권한적인 요청인지를 구분하기 위해 사용자가 작업페이지를 요청할 때마다 hidden값으로 클라이언트에게(토큰을 전달한 뒤 해당 클라이언트의 데이터 처리 요청시 전달되는 값과 세션에 저장된 값을 비교하여 유효성을 검사한다.

- ㉠ XSS 필터링
 ㉡ CAPTCHA
 ㉢ CSRF 토큰
 ㉣ COOKIE SECURE 옵션

49. 다음 문장에서 설명하는 보안시스템은?

UTM, DLP, SSL Inspection, SSL VPN, Anti APP 등 다양한 기능을 통합해 지원하며, Layer 7 까지 제어하고 암호화 트래픽 제어 가능한 보안 시스템

- ㉠ NGFW(Next Generation Firewall)
 ㉡ NAC(Network Access Control)
 ㉢ IPS(Intrusion Prevention System)
 ㉣ WIPS(Wireless Intrusion Prevention System)

50. 디지털 콘텐츠의 무단 복제 및 사용을 막고 원작자의 권리와 이익을 보호해 주는 기술과 서비스를 통칭하는 용어는?

- ① DRM(Digital Rights Management)
- ② ECRM(Electronic Customer & Relationship Management)
- ③ TPM(Total Productive Maintenance)
- ④ SSL(Secure Sockets Layer)

51. HTTP 요청 메시지를 구성하는 순서로 옳은 것은?

- ① Request line → header → blank line → body
- ② Request line → blank line → header → body
- ③ Request line → header → body → blank line
- ④ Request line → body → blank line → header

52. 다음 문장은 어떤 FTP(File Transfer Protocol) 공격 유형을 설명하고 있는가?

이 FTP 공격은 인접 FTP 서버를 이용해 그 FTP 서버를 경유해서 호스트를 스캔하며, FTP PORT 명령을 이용하고, FTP 서버를 통해 임의의 네트워크 접속을 릴레이하며, 네트워크를 포트 스캐닝하는데 사용하는 공격이다.

- ① Brute Force 공격
- ② FTP 서버 자체 취약점 공격
- ③ Anonymous FTP Attack
- ④ Bounce Attack

53. 소프트웨어 보안 취약점 중에서 입력값 검증 및 표현과 관련이 없는 것은?

- ① SQL 인젝션
- ② 경로조작 및 파일 삽입
- ③ 위험한 형식의 파일 업로드
- ④ 경쟁조건

54. DNS 서비스를 위해 BIND 설치시 관련이 없는 항목은?

- ① /etc/named.conf
- ② /etc/named.iscdlv.key
- ③ /etc/named.rfc1912.zones
- ④ /etc/root.rndc.key

55. XML 디지털 서명의 유형이 아닌 것은?

- ① Enveloping Signature
- ② Enveloped Signature
- ③ Detached Signature
- ④ Keyinfo Signature

56. 전자투표 시스템이 가져야 할 암호 기법이 아닌 것은?

- ① 공개키/개인키를 이용한 암호화 및 복호화
- ② 전자 서명(Digital Signature)
- ③ 유닉암호
- ④ 포그 컴퓨팅(Fog Computing)

57. 높은 수준의 권한을 가진 사용자들만이 접근할 수 있는 정보를 낮은 수준의 권한을 가진 사용자들이 접근할 수 있는 객체에 저장하였다. 이것은 DB 보안의 어떤 통제를 위반하는 것인가?

- ① 접근 통제
- ② 추론 통제
- ③ 무결성 통제
- ④ 흐름 통제

58. 웹 응용프로그램에서 운영체제 명령어 삽입 취약점이 존재할 경우 사용할 수 있는 특수문자를 사용한 명령어 조합으로 틀린 것은?

- ① pwd;ls -al : pwd 명령과 ls 명령이 순차적으로 실행된다.
- ② pwd || ls -al : pwd 명령이 실패해야 ls -al 명령이 실행된다.
- ③ ls -al | more : ls 명령의 결과값을 more 명령의 입력값으로 사용한다.
- ④ ls && pwd : ls 명령이 실패해야 pwd 명령이 실행된다.

59. SMTP 서버의 릴레이 기능 제한 여부 점검시 틀린 것은?

- ① vi 편집기를 이용하여 sendmail.cf 설정파일을 열어 아래와 같이 주석을 제거한다.
RS* \$#error \$@ 5.7.1 \$: "550 Relaying denied"
- ② /etc/mail/access 파일을 삭제한다.
- ③ /etc/mail/access에 특정 IP, Domain, Email Address 및 네트워크에 대한 sendmail 접근제한을 확인한다.
localhost.localdomain RELAY
localhost RELAY
127.0.0.1 RELAY
spam.com REJECT
- ④ 수정을 했거나 생성했을 경우 makemap 명령으로 DB 파일을 생성한다.
makemap hash /etc/mail/access.db < /etc/mail/access

60. 포렌식 기의 기본 원칙에 대한 설명으로 틀린 것은?

- ① 정당성의 원칙 : 모든 증거는 적법한 절차를 거쳐서 획득한 것이어야 하며, 위법한 절차를 거쳐 획득한 증거는 증거 능력이 없다.
- ② 채취의 원칙 : 법정에서 증거를 제출하려면 똑같은 환경에서 같은 결과가 나오도록 제한할 수 있어야 한다.
- ③ 신속성의 원칙 : 컴퓨터 내부의 정보는 휘발성을 가진 것이 많기 때문에 신속하게 처리해야 한다.
- ④ 무결성의 원칙 : 수집된 정보는 원계 보관성을 만족시켜야 하고, 각 단계를 거치는 과정에 대한 추적이 불가능해야 한다.

정보보안일반

61. MAC(Message Authentication Code)에 대한 설명으로 틀린 것은?

- ① MAC은 데이터가 불법적으로 수정, 삭제, 삽입되었는지를 검증할 목적으로 데이터에 덧붙이는 코드이다.
- ② 공격자는 변조된 데이터에 대한 MAC을 생성 및 기존 MAC을 대체하여 데이터 수신자를 속일 수 있으므로 MAC의 생성 및 검증 과정에서는 반드시 송수신자가 공유한 비밀키를 사용해야 한다.
- ③ 수신자는 전송된 메시지에 대한 MAC을 계산한 다음 수신한 MAC과 비교하여 메시지의 위변조 여부를 검증한다.
- ④ MAC은 메시지의 위변조 검증만 수행하기 때문에 MAC 생성에 이용되는 해시함수의 안전성은 MAC의 안전성과는 무관하다.

62. 금융보안에서의 데이터 접근 통제에 대한 설명으로 틀린 것은?

- ① 부정거래 패턴(규칙) 및 사용자 정보 등 시스템 운영에 필요한 데이터 또는 패턴 생성·변경·삭제 등의 관리 기능
- ② 비인가 관리자 또는 역할이 서로 다른 관리자가 사전에 정한 패턴 및 데이터의 무단 생성·변경·삭제 등의 권한 기능
- ③ 비인가 행위를 예방하는 송·수신 데이터의 통제 기능
- ④ 접속일시, 접속성공 및 실패, 접근IP, MAC, 계정유형, 서비스 열람·변경·삭제 등의 행위기록 기능

63. Kerberos 키 분배 프로토콜의 기반 기술에 해당하는 것은?

- ① Needham-Schroeder 프로토콜
- ② Challenge-Response 프로토콜
- ③ Diffie-Hellman 프로토콜
- ④ RSA 이용 키 분배 프로토콜

64. 인증서의 생성, 발행, 폐기 관리를 하는 기관은?

- ① CA
- ② RA
- ③ VA
- ④ CRL

65. 다음 문장에서 설명하는 프로토콜은?

공개키 암호에 대한 시도가 되었으며 두 사용자가 안전하게 키를 교환하는 방식으로 이 프로토콜의 효용성은 이산대수 계산의 어려움에 의존한다.

- ① Needham-Schroeder 프로토콜
- ② RSA 프로토콜
- ③ Diffie-Hellman 프로토콜
- ④ 커버로스 프로토콜

66. 대칭키 암호 알고리즘 중 국내에서 권고하고 있는 알고리즘이 아닌 것은?

- ① SEED
- ② HIGHT
- ③ LEA-128/192/256
- ④ DES

67. 다음 문장에서 설명하는 접근통제 모델은?

- 무결성 레벨에 따라서 정보 접근 제한
- No Write up
- No read down

- ① 비바 모델
- ② 벨 라파들라 모델
- ③ RBAC 모델
- ④ 인증 패스워드 모델

68. 다음 중 X.509 인증서 구조의 내용이 아닌 것은?

- ① 버전(Version)
- ② 일련번호(Serial Number)
- ③ 비밀키 정보(Private Key Information)
- ④ 유효기간(Period of Validity)

69. SHA-384(Secure Hash Algorithm)의 Block Size는? ^{SHA-1} 512

① 160
② 224
③ 512
④ 1024

70. 디지털 서명에 대한 공격을 예방하기 위해 공개키를 취급하는 소프트웨어는 공개키의 해시값을 표시하는 속단을 준비해놓고 있다. 이러한 해시값을 무엇이라 하는가?

① 인증서
② 핑거프린트
③ 키 블록
④ 패딩

71. 패스워드 입력 방식에 대한 단점을 개선한 인증기술로 스마트폰과 같은 디바이스에서 사용하는 인증수단을 온라인에 연동하여 사용자를 인증하는 기술은?

① HSM
② mOTP
③ 지문
④ FIDO

72. RSA 공개키 암호화 방식의 키 교환 사용 설명으로 틀린 것은?

① RSA는 공개키/개인키 쌍인 $K_{UA} = \{e, n\}$, $K_{RA} = \{d, n\}$ 를 사용한다.
② A가 암호화 되지 않은 평문으로 A의 공개키를 B에게 전송한다.
③ B는 공유 비밀키를 생성, A에게서 받은 A의 공개키로 암호화 전송한다.
④ 암호화할 때의 키를 개인키(Private Key), 복호화할 때의 키를 공개키(Public Key)라고 한다.

73. 공개키 기반 구조(PKI)에서 최상위 인증 기관(CA)을 무엇이라 하는가?

① Top CA
② Super CA
③ Root CA
④ Ultra CA

74. 생체인증 기술의 정확성을 나타내는 FRR(False Rejection Rate)와 FAR(False Acceptance Rate)에 대한 설명으로 틀린 것은?

① 시스템에 접근하려 할 때, FAR이 높으면 사용자 편의성이 증대된다.
② 시스템에 접근하려 할 때 FRR이 낮으면 사용자 편의성이 증대된다.
③ 시스템의 생체인증 보안성을 강화하게 되면 FRR이 높아진다.
④ 시스템의 생체인증 보안성을 강화하게 되면 FAR이 높아진다.

75. 다음 중 온라인 열쇠 분배방법인 Kerberos 방식에 대한 설명으로 틀린 것은?

① 분산 컴퓨팅 환경에서 대칭키를 이용하여 사용자 인증을 제공하는 중앙 집중형 인증 방식이다.
② 데이터의 기밀성은 보장되지만 무결성은 보장하지 못하는 치명적인 단점이 있다.
③ 사용자의 비밀키가 사용자의 워크스테이션에 임시로 저장되므로 침입자에 의해 유출될 가능성이 있다.
④ 패스워드 추측 공격에 취약하다.

76. CTR(Counter) 모드에 대한 설명으로 틀린 것은?

① 이전 암호문 블록과 독립적인 키 스트림을 생성하지 않는다.
② 키 스트림의 의사난수성은 카운터를 사용함으로써 성취될 수 있다.
③ 암호화시 피드백이 존재하지 않는다.
④ 서로 독립적인 n비트 암호문 블록을 생성한다.

77. 메시지에 대한 충돌저항성을 갖는 해시함수를 설계할 경우 공격자가 2개개의 해시값을 계산할 수 있는 능력이 있고 정보의 가치가 1,024초 이후에는 위조가 되어도 된다고 하면 공격자가 충돌쌍을 찾지 못하도록 하는 최소 해시값의 비트수는?

① 32
② 64
③ 84
④ 96

78. 일방향 해시함수에 대한 설명으로 틀린 것은?

① SHA-256의 해시값은 32바이트이다.
② 일방향 해시함수를 사용해서 메시지 인증코드를 구성할 수 있다.
③ SHA-1에 대한 충돌 내성은 깨지지 않아 안전하게 사용할 수 있다.
④ 일방향 해시함수를 통해 파일의 무결성을 보장할 수 있다.

79. 사용자 역할에 기반을 두고 접근을 통제하는 RBAC(역할기반 접근통제) 모델에 대한 설명으로 틀린 것은?

① 주체의 인사이동이 갖은 조직에 적합한 접근통제 방식이다.
② 자원관리자 혹은 보안 관리자가 자원 접근 권한을 다른 사용자에게 부여한다.
③ 임의적 접근통제 방식과 강제적 접근통제 방식의 단점을 보완한 접근통제 기법이다.
④ 최소권한의 원칙과 격무불리의 원칙을 지킨다.

80. Diffie-Hellman 키 분배 프로토콜을 이용하여 송신자 "A"와 수신자 "B"간에 동일한 비밀키를 분배하고자 한다. 다음과 같은 조건이 주어졌을 때, 송신자 "A"와 수신자 "B"가 분배받은 비밀키는?

- Diffie-Hellman 키 분배 프로토콜에서 사용하는 이산 대수 : $g^a \bmod p$
- 송신자 A : $g = 3, p = 7, a = 2$
- 수신자 B : $g = 3, p = 7, a = 3$

① 1
② 3
③ 5
④ 7

$3^{2 \times 3} \bmod 7 = 3^6 \bmod 7 = 104 \bmod 7 = 2$

81. 계정동용 및 불법적인 인증시도 통제방안으로써 '불법' 로그인 시도 경고 통제방안 예시로 올바르지 않은 것은?

① 해의 IP주소 등 동용되지 않은 IP주소에서의 접속시 차단 및 통지
② 주말, 야간 접속시 통지 알림
③ 관리자 등 특수 권한 로그인시 알림
④ 동일 계정으로 동시 접속시 접속차단 조치 또는 알림 기능

82. 개인정보보호법에 따른 권리의 보유 및 행사 주체인 정보주체에 해당하지 않는 것은?

① 처리되는 정보에 의하여 알아볼 수 있는 사람
② 개인정보를 처리하는 사람
③ 처리되는 정보의 주체가 되는 사람
④ 법인이나 단체가 아닌 살아있는 사람

83. 개인정보보호법상 정보주체의 동의없이 사용할 수 없는 사례는?

① 통계작성, 과학적 연구, 공익적 기록보존 등을 위해 2명처리 후 사용하였다.
② 범죄의 수사와 공소의 제기 및 유지를 위해 정보주체의 민감정보를 수집하였다.
③ 공공기관의 자체감사를 하며, 해당 직원의 개인정보를 처리하였다.
④ 인터넷사이트를 운영하면서 SNS 회사로부터 이용자의 이름, 휴대폰 번호, 이메일, 주소를 제공받아 사용하였다.

84. 지식정보통신 컨설팅전문업체로 지정받을 수 있는 법인 원천의 결격사유가 아닌 것은?

① 미성년자
② 파산선고를 받고 복권되지 아니한 사람
③ 금고 이상의 형의 집행유예를 선고받고 그 유예기간 중에 있는 사람
④ 벌금형을 받고 벌금을 미납한 사람

85. 개인정보처리에 관한 설명으로 틀린 것은?

① 개인정보보호법은 인터넷 공간과 내부망의 중간지점에 고유식별정보를 저장하는 경우에는 이를 암호화하도록 요구하고 있다.
② 정보통신망 이용촉진 및 정보보호 등에 관한 법률은 개인정보취급자별로 한 개의 사용자계정을 발급하도록 요구하고 있다.
③ 영상정보처리기기운영자는 영상정보처리기기의 설치 목적과 다른 목적으로 영상정보처리기기를 임의로 조작하거나 다른 곳을 비추시는 아니되며, 녹음기능은 사용할 수 없다.
④ 학술연구 등의 목적을 위하여 필요한 경우로서 특정 개인을 알아볼 수 없는 형태로 개인정보를 제공하는 경우에는 정보주체의 동의없이 개인정보를 이용·제공할 수 있다.

86. GDPR의 적용 대상으로 틀린 것은?

- ① EU주민의 정보와 무관하지만 제공하는 물품과 서비스에 EU의 생산품이 포함된 기업
- ② EU지역에 사업장을 없지만 인터넷 홈페이지를 통해 EU에 거주하는 주민에게 물품 및 서비스를 제공하는 기업
- ③ EU에 거주하는 주민의 행동을 모니터링하는 기업
- ④ EU에 사업장을 운영하는 기업

87. 외주 및 협력업체의 인력에 대한 보안을 강화하기 위한 보호대책으로 틀린 것은?

- ① 외부위탁 용역 및 협력업체 인력과의 계약서에 보안관련 사항을 포함시켜야 한다.
- ② 협력업체 직원 등의 외주 인력은 회사 업무 수행시 내부 직원과 동일한 수준으로 정보보호 정책을 준수하여야 한다.
- ③ 외주 인력에게 회사의 중요 정보에 접근을 허용하는 경우 한시적으로 제한하여 허용하고 주기적인 점검이 이루어져야 한다.
- ④ 업무상 필요에 의해 협력업체 직원이 회사 정보시스템에 대한 접속 및 외부로의 접속이 요구되는 경우 협력업체 책임자의 승인을 받는다.

88. 정보보호 정책을 구현하기 위한 요소에 대한 설명으로 틀린 것은?

- ① 정책은 조직의 경영 목표를 반영하고 정보보호 관련 상위 정책과 일관성을 유지한다.
- ② 표준은 정보보호 정책의 상위 개념이며 정책 목적을 달성하기 위하여 세부적인 사항을 사규 또는 내규 등으로 정리한 내용으로 조직 내에서 준수하도록 하는 강제성은 없다.
- ③ 지침은 정보보호의 정책을 달성하기 위해 도움이 될 수 있는 구체적인 사항을 설명한 권고 사항으로 정보보호 활동에 필요하거나 도움이 되는 세부 정보를 설명하는 내용이다.
- ④ 절차는 정책을 만족하기 위하여 수행하여야 하는 사항들을 순서에 따라 단계적으로 설명하며 구체적 취용을 위해 필요한 세부적인 방법을 기술한 내용이다.

89. 다음 중 일반직원 대상의/특수직원의 정보보호 교육 및 훈련의 내용에 해당되지 않는 것은?

- ① 정보보호 요구사항
- ② 정보보호 사고 발생시 사용자의 법적인 책임
- ③ 조직의 정보보호 관리체계 방법
- ④ 조직의 정보보호 시스템 구성도 및 운영방법

90. 업무연속성관리 단계가 아닌 것은?

- ① 전략수립단계
- ② 구현단계
- ③ 운영관리단계
- ④ 종료단계

91. 사회공학 기법을 악용한 보이스피싱, 전자금융사기 등 금융소비자 대상의 공격이 고도화·지능화됨에 따라 각 금융회사는 금융소비자의 재산을 보호하기 위한 시스템으로 오후9시에 종로의 편의점에서결제된 신용카드가 당일 오후9시5분에 모스크바에서 결제요청되는 등의 이상금융거래를 탐지해주는 시스템은?

- ① FDS, Fraud Detection System
- ② DLP, Data Loss Prevention
- ③ RMS, Risk Management System
- ④ ESM, Enterprise Security Management

92. 정보통신 서비스 제공자가 개인정보 유출시 이용자에게 알려야 하는 법률적 의무사항으로 옳지 않은 것은?

- ① 이용자가 상담 등을 접수할 수 있는 부서 및 연락처
- ② 유출 등이 발생한 원인
- ③ 정보통신서비스 제공자 등의 대응 조치
- ④ 이용자가 취할 수 있는 조치

93. 클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률에서 정의하는 용어에 대한 설명으로 틀린 것은?

- ① "클라우드컴퓨팅"이란 정보통신자원을 이용자의 요구나 수요 변화에 따라 정보통신망을 통하여 신속적으로 이용할 수 있도록 하는 정보처리체계를 말한다.
- ② "클라우드컴퓨팅기술"이란 클라우드컴퓨팅의 구축 및 이용에 관한 정보통신기술로서 가상화 기술, 분산처리 기술 등을 말한다.
- ③ "클라우드컴퓨팅서비스"란 클라우드컴퓨팅을 활용하여 상용으로 타인에게 정보통신자원을 제공하는 서비스 등을 말한다.
- ④ "이용자 정보"란 클라우드컴퓨팅서비스 이용자가 클라우드컴퓨팅서비스에 등록하는 계정 정보를 말한다.

94. 다음 중 디지털 저작권에 대한 설명으로 틀린 것은?

- ① 본인이 촬영하고 편집한 동영상은 저작물에 따로 등록하지 않아도 저작권이 적용될 수 있다.
- ② 온라인 비대면 수업과 회의 참가자의 사진을 허락없이 촬영하여 업로드한 경우 초상권 침해가 될 수 있다.
- ③ 공공데이터포털에서 공개하고 있는 데이터의 경우 저작권자는 공개한 공공기관이므로 공공 데이터는 별도의 저작권자의 이용 허락없이 활용할 수 있다.
- ④ 비영리적 목적으로 사용하도록 승인한 공개 소프트웨어는 개인, 기업 모두 자유롭게 사용할 수 있다.

95. 다음 중 위험 분석 접근 방법에 대한 설명으로 틀린 것은?

- ① 기초적 접근법은 모든 시스템에 대하여 표준화된 보호대책의 세트를 흐름도의 형태로 제공하며, 계량화가 가능한 장점이 있다.
- ② 비정형적 접근법은 경험자의 지식에 기반하지 않고 구조적인 방법론을 사용하여 위험 분석을 수행하는 방식이다.
- ③ 상세 위험 분석 접근법은 자산분석, 위험 분석, 취약점 분석의 각 단계를 수행하여 위험을 평가하는 방법이다.
- ④ 복합 접근법은 고위험 영역을 식별하여 베이스라인 접근법을 사용하고, 다른 영역은 비정형 접근법을 사용하여 효율적으로 소규모의 조직 위험 평가를 실시할 때 유용한 방법이다.

96. 다음 문장에서 괄호 안에 들어갈 내용은?

위험이란 비정상적인 일이 발생할 수 있는 ()을 말하며, ()분석은 ()을 분석하고 해석하는 과정으로 조직 자산의 ()을 식별하고, ()분석을 통해 발생 가능한 위험의 내용과 정도를 결정하는 과정이다.

- ① ㉠ : 가능성 ㉡ : 위험 ㉢ : 취약성 ㉣ : 위협
- ② ㉠ : 취약성 ㉡ : 위험 ㉢ : 가능성 ㉣ : 위협
- ③ ㉠ : 확률 ㉡ : 위험 ㉢ : 취약성 ㉣ : 위협
- ④ ㉠ : 가능성 ㉡ : 위험 ㉢ : 취약성 ㉣ : 위협

97. 거버넌스 체계에 있어서 정보보호에 대한 경영진의 관심 및 참여가 정보보호 목표 달성에 있어서 제일 중요한 요소이다. 정보보호 운영활동 전반에 경영진의 참여가 이루어질 수 있도록 보고하고 경영진이 정보보호 관련 의사결정에 참여할 수 있도록 운영해야 한다. 다음 중 경영진 참여에 대한 사항으로 가장 부적절한 것은?

- ① 경영진 참여가 이루어질 수 있도록 보고, 의사결정 등의 책임과 역할을 문서화하지 않았지만 정기적으로 보고하고 있다.
- ② 경영진이 직접 정보보호 활동에 참여도 가능하지만 정보보호 위원회를 구성하여 중요한 의사결정 등을 결정할 수 있다.
- ③ 조직의 규모 및 특성에 맞게 보고 및 의사결정 절차, 대상, 주기 등을 결정할 수 있다.
- ④ 경영진 참여가 원칙이나 내부 위임전결 등의 규정이 있는 경우에는 정보보호를 담당하고 있는 책임자가 경영진의 의사결정을 대행할 수 있다.

98. 정보보안관리 및 보안제어에 대한 프라이버시의 연장선에 있는 국제경영시스템으로 조직이 개인정보를 관리하는 방법을 포함하여 프라이버시 보호에 대한 지침을 제공하고 전 세계의 프라이버시 규정 준수를 입증하는 표준은?

- ① ISMS-P
- ② ISMS
- ③ ISO27001
- ④ ISO27701

99. 조직의 위험평가를 수립하고 운영에 대한 사항으로 적절하지 않은 것은?

- ① 위험관리를 위한 위험평가 방법 선정은 베이스라인 접근법, 상세위험 분석법, 복합 접근법, 위험 및 시나리오 기반 등의 다양한 방법론 중에서 해당 조직에 맞는 방법론을 선정하고 유지하여야 한다. 선정된 방법론을 운영하는 과정에서 해당 조직에 적절하지 않다고 판단하여 위험분석 방법론을 변경하여도 상관없다.
- ② 위험관리를 위한 수행능력, 기간, 대상, 예산 등의 방법 및 절차를 구체화한 위험관리계획을 수립하여야 하며, 위험평가 참여자는 외부위험관리전문가로 구성된다.
- ③ 위험관리 계획에 따라 위험평가를 연 1회 이상 정기적으로 또는 필요한 시점에 수행하여야 한다. 매년 위험평가 대상에 변동이 없어도 위험평가는 수행되어야 한다.
- ④ 조직에서 수용 가능한 목표 위험수준을 정하고 그 수준을 초과하는 위험을 식별하여야 한다. 수용 가능한 목표 위험수준(DoA, Degree of Assurance)을 정보보호 최고책임자 등 경영진 의사결정에 의하여 결정하여야 한다.

100. 유럽의 국가들이 자국의 정보보호시스템을 평가하기 위해 각각의 기준을 제정하여 시행하는 것은?

- ① TCSEC
- ② ITSEC
- ③ TNI
- ④ PDI